All’Ecc.mo Collegio dei docenti del Dottorato di ricerca in Scienze Giuridiche

Report annuale relativo alle attività svolte durante il III anno del Corso di Dottorato di ricerca in Scienze giuridiche Persona, Mercato e Nuove Tecnologie, XXXIX ciclo, a.a. 2025-2026

Il sottoscritto Francesco Paolo Micozzi, iscritto, per l’A.A. 2025/2026 al terzo anno del corso di Dottorato di ricerca in Scienze giuridiche, curriculum Persona, Mercato e Nuove Tecnologie, XXXIX ciclo, con matricola 372431, illustra di seguito l’attività di ricerca svolta nel corso del terzo anno e lo stato di avanzamento della stessa, che si è conclusa con la redazione della tesi di dottorato. Nella relazione, inoltre, sono indicate le partecipazioni alle attività formative proposte, ai seminari/congressi in sede e fuori sede, nonché l’elenco delle pubblicazioni prodotte.

La tematica d’interesse è quella relativa alla “Prevenzione e mitigazione dei data breach e degli incidenti di sicurezza informatica nelle imprese e nelle pubbliche amministrazioni”.

Il terzo anno di dottorato, conformemente al cronoprogramma del progetto di ricerca, è stato dedicato alla stesura dell’elaborato finale, nel quale sono confluiti i risultati delle attività svolte nel primo e nel secondo anno: l’analisi degli effetti dei data breach in ambito pubblico e privato, degli strumenti tecnici di auditing e di analisi del rischio, dei nuovi impianti normativi europei e nazionali in materia di cibersicurezza e di intelligenza artificiale, degli standard tecnici di settore e della prospettiva comparatistica con l’ordinamento brasiliano.

Nel corso dell’anno sono stati inoltre sviluppati i profili annunciati nella precedente relazione. Il tema della sovranità tecnologica ha trovato una specifica trattazione, nella quale la sovranità digitale europea è letta come politica dell’affidabilità; le indicazioni di R. Garofoli e B.G. Mattarella sulla necessità di istituzioni capaci di fronteggiare le vulnerabilità strutturali e digitali (*Governare le fragilità. Istituzioni, sicurezza nazionale, competitività*, 2025) sono state riprese nelle conclusioni; il modello dell’architettura delle scelte di R.H. Thaler e C.R. Sunstein (*Nudge*) è stato impiegato per l’analisi della decisione assistita da sistemi di intelligenza artificiale e dell’effettività della sorveglianza umana. Il tema del principio di precauzione è stato ricondotto a quello, più generale, del governo giuridico dell’incertezza, che costituisce il filo conduttore della tesi.

Attività di ricerca svolta e stato d’avanzamento

Nel periodo di riferimento l’attività di ricerca si è concentrata sulla sistematizzazione dei materiali raccolti e sulla redazione della tesi. L’elaborato muove dalla constatazione che le discipline della sicurezza non si limitano a prescrivere difese, ma obbligano a valutare i rischi prima che si concretizzino, a riesaminare le valutazioni quando il contesto muta, a documentare il percorso seguito, a notificarne gli esiti e a organizzare il modo stesso in cui si decide, sanzionando spesso l’inadempimento di tali obblighi anche prima e indipendentemente dal danno. La tesi si articola in un’introduzione e in quattro parti:

- **Parte I – La costruzione della teoria**: conoscenza, decisione e diritto in condizioni di incertezza; la giuridificazione della cognizione e i suoi antecedenti pre-digitali; l’affidabilità come concetto giuridico, nella tripartizione fra affidabilità sostanziale, rappresentata e apparente; affidamento, esposizione e fiducia sistemica;

- **Parte II – Artefatti epistemici e decisione**: gli output dei sistemi di intelligenza artificiale impiegati come elementi conoscitivi nelle decisioni; il collasso della garanzia per specifica e la superficie d'attacco semantica (*prompt injection*, *data* e *model poisoning*); le architetture della decisione, l'*automation bias* e la sorveglianza umana sostanziale e apparente;
- **Parte III – La verifica positiva**: la lettura, attraverso sei funzioni (acquisizione, aggiornamento, impiego, documentazione, circolazione della conoscenza e responsabilità per deficit cognitivo-organizzativo), del diritto dell'Unione (GDPR, NIS2, DORA, AI Act, CRA), dell'ordinamento italiano (d.lgs. 231/2001, d.lgs. 138/2024, L. 90/2024, L. 132/2025 e relativi decreti attuativi) e dell'ordinamento brasiliano (LGPD, regolazione dell'ANPD, Emenda Constitucional n. 115/2022, giurisprudenza del Supremo Tribunal Federal, progetto di legge sull'intelligenza artificiale);
- **Parte IV – I verdetti**: quattro casi di studio (prompt injection contro un agente della pubblica amministrazione, errore diagnostico di un sistema sanitario, decisione amministrativa automatizzata, poisoning di un sistema in apprendimento continuo), gli esiti della verifica delle ipotesi, le conclusioni e il programma di ricerca post-dottorale.

Rispetto alle domande di ricerca formulate nel progetto, la tesi giunge a una risposta differenziata: il quadro normativo vigente appare solido nel fondare doveri di prevenzione anteriori al danno, mentre risulta meno uniforme nell'imputazione della loro violazione (anche per il trattamento sanzionatorio più lieve riservato, nel recepimento italiano della NIS2, ai soggetti pubblici) e meno sviluppato sul piano dei rimedi alle conseguenze degli incidenti. Ne discendono alcune proposte *de iure condendo*, tra le quali il rafforzamento della raccolta dei quasi-incidenti, una protezione probatoria calibrata delle segnalazioni, l'obbligo di ricostruire e riesaminare le decisioni assunte mentre un sistema era compromesso, una tutela più uniforme dei soggetti esposti agli effetti degli incidenti e la verifica effettiva delle competenze degli organi di amministrazione in materia di cibersicurezza.

Scostamenti rispetto al progetto di ricerca iniziale e relative motivazioni

Il progetto di ricerca, presentato nel luglio 2023, era incentrato sull'efficacia del GDPR e della legislazione italiana nella prevenzione dei data breach e si limitava a prevedere che un rilevante impatto avrebbe assunto il futuro regolamento europeo sull'intelligenza artificiale, «pur in assenza di un testo normativo definitivo». Nel corso del triennio il quadro normativo di riferimento è profondamente mutato, per effetto di atti entrati in vigore o divenuti applicabili dopo l'ottobre 2023, tra i quali:

- il regolamento (UE) 2024/1689 sull'intelligenza artificiale (AI Act), del 13 giugno 2024, considerato anche nella versione modificata dal regolamento (UE) 2026/1744;
- il regolamento (UE) 2024/2847 sui requisiti di cibersicurezza dei prodotti con elementi digitali (Cyber Resilience Act) e la direttiva (UE) 2024/2853 sulla responsabilità per danno da prodotti difettosi, entrambi del 23 ottobre 2024;
- il regolamento (UE) 2022/2554 sulla resilienza operativa digitale del settore finanziario (DORA), applicabile dal 17 gennaio 2025;
- il d.lgs. 4 settembre 2024, n. 138, di recepimento della direttiva (UE) 2022/2555 (NIS2), e la L. 28 giugno 2024, n. 90, in materia di cibersicurezza e di reati informatici;

- la L. 23 settembre 2025, n. 132, sull'intelligenza artificiale, e i successivi decreti legislativi attuativi 9 settembre 2026, n. 160, e 7 ottobre 2026, n. 179.

Questa evoluzione ha reso necessario un ampliamento dell'oggetto della ricerca, che è stato condotto senza abbandonare le domande d'origine. Le ragioni dello scostamento sono essenzialmente due.

La prima è di ordine cronologico. Gran parte degli atti sui quali si è esercitata la verifica è sopravvenuta dopo la presentazione del progetto: un progetto che, nel 2023, avesse posto al centro l'intelligenza artificiale avrebbe dovuto ragionare su proposte di atti non ancora approvati, mentre il materiale normativo formatosi in seguito ha consentito di estendere l'indagine a discipline vigenti. Alle domande di ricerca originarie (D1–D4) la tesi risponde espressamente, nella parte dedicata agli esiti della verifica.

La seconda ragione è di merito. Le nuove discipline condividono con il GDPR e con la NIS2 la medesima struttura di obblighi di valutazione, aggiornamento, documentazione e notifica dei rischi, sicché lo studio della prevenzione dei data breach non poteva più essere condotto isolando la sola normativa sulla protezione dei dati personali. L'intelligenza artificiale, inoltre, rileva sotto un triplice profilo: come nuovo oggetto di rischio (si pensi alla contaminazione dei dati di addestramento o alla dipendenza da componenti non conoscibili), come strumento della sicurezza (che può entrare nello standard di diligenza richiesto dall'art. 32 del GDPR) e, soprattutto, come fattore che mette in discussione la premessa sulla quale poggiano gli obblighi di valutazione del rischio, cioè che la conoscenza su cui si decide sia prodotta da soggetti in grado di comprenderla e di giustificarla. Per queste ragioni l'oggetto della ricerca si è spostato dal data breach in senso stretto al diritto della sicurezza inteso come governo preventivo dell'incertezza, ferma restando la protezione dei dati, dei sistemi e delle persone quale finalità ultima degli obblighi esaminati.

Lo scostamento ha comportato anche alcuni adattamenti di metodo, che si indicano per completezza:

- le ipotesi del progetto, formulate in termini di correlazione tra variabili normative e numero dei data breach, avrebbero richiesto dati quantitativi completi e attendibili sugli incidenti, la cui limitata disponibilità era già segnalata nel progetto (non tutti i data breach vengono scoperti o notificati); esse sono state perciò riformulate in quattro ipotesi verificabili sui testi normativi (unità funzionale, affidabilità dinamica, tutela duale, migrazione dell'*assurance*), con condizioni di falsificazione fissate prima della verifica e non modificate durante;
- le interviste semi-strutturate a esperti di sicurezza informatica e a responsabili della sicurezza delle informazioni, previste dal progetto, sono risultate in corso d'opera non rilevanti ai fini della verifica delle ipotesi così riformulate, il cui oggetto è divenuto la struttura degli obblighi imposti dai testi normativi, che non può essere accertata attraverso le percezioni degli operatori. L'attività di ricerca è stata perciò indirizzata all'analisi del corpus normativo, mentre l'applicazione effettiva delle disposizioni è stata studiata attraverso la giurisprudenza, i provvedimenti delle autorità e i casi di studio. La rilevazione sul campo delle pratiche organizzative conserva invece interesse per misurare l'effettività degli obblighi, e la tesi la colloca nel programma empirico della ricerca post-dottorale;

- in luogo della rilevazione mediante interviste, la verifica è stata impostata su una classificazione del corpus normativo secondo regole scritte, sperimentata su un campione di disposizioni classificato separatamente da due lettori indipendenti. La prova ha prodotto un risultato di cui la tesi tiene espressamente conto: la concordanza fra i due lettori non ha raggiunto, su nessuna delle variabili considerate, la soglia fissata in anticipo, sicché la classificazione dell'intero corpus non è stata eseguita e le sei funzioni sono state impiegate come criterio di lettura dichiarato, con regole esplicite enunciate all'apertura della Parte III. Il risultato ha inciso sul giudizio sulle ipotesi, formulato su argomenti controllabili anziché su misure, e costituisce esso stesso un esito metodologico della ricerca, perché mostra che una classificazione giuridica che richiede molte valutazioni interpretative non si trasmette fra lettori indipendenti attraverso le sole regole scritte; la tesi indica inoltre le condizioni per una replica della prova (lettori addestrati sulle regole, campione stratificato, confronto in due fasi);
- la comparazione, che il progetto prospettava con riferimento a ordinamenti quali quelli statunitense e canadese, è stata condotta con l'ordinamento brasiliano, preferito perché la capacità della griglia di analisi di distinguere gli obblighi si misura meglio su un ordinamento che non ha contribuito a formarla, e perché la disciplina brasiliana, pur ispirata al GDPR, presenta formanti propri (giurisprudenziale, costituzionale e regolamentare) che consentono di osservare fenomeni di convergenza, ibridazione e resistenza;
- il prontuario-vademecum per la gestione dei data breach, che il cronoprogramma collocava nell'ultima parte del terzo anno, non è stato inserito nell'elaborato. Le indicazioni operative che esso dovrebbe contenere possono trarre origine dall'ultima parte della tesi, e in particolare dai casi di studio, che declinano le sei funzioni in obblighi concreti di imprese e amministrazioni, e dalle proposte *de iure condendo*; la loro traduzione in uno strumento pratico appare tuttavia più utile all'esito dell'eventuale prosecuzione post-dottorale della ricerca, quando il programma empirico avrà consentito di verificare sul campo le pratiche delle organizzazioni e di monitorare l'attuazione delle discipline più recenti, molte delle quali sono entrate in vigore soltanto negli ultimi mesi del triennio.

Periodi di ricerca all'estero

Nel corso del triennio una parte significativa dell'attività di ricerca è stata svolta all'estero, per complessivi sei mesi circa, essenzialmente in Brasile – presso la Universidade do Vale do Itajaí (Univali), in attuazione dell'accordo di collaborazione con l'Università degli Studi di Perugia, presso ATITUS Educação e presso la Faculdade de Direito de Franca – oltre a un breve periodo presso l'Escuela Judicial del Poder Judicial del Estado de Oaxaca (Messico), già indicato nella relazione del primo anno. I periodi trascorsi in Brasile hanno consentito di approfondire l'ordinamento brasiliano in materia di protezione dei dati personali e di sicurezza delle informazioni (la Lei Geral de Proteção de Dados Pessoais, la regolazione e l'attività dell'Autoridade Nacional de Proteção de Dados, la giurisprudenza del Supremo Tribunal Federal e il dibattito sulla regolazione dell'intelligenza artificiale), anche attraverso il confronto con la dottrina brasiliana e la partecipazione a congressi internazionali. L'ordinamento brasiliano costituisce il termine di comparazione della tesi, alla quale è dedicato un apposito capitolo (Parte III, cap. 3, "Il Brasile come test discriminante").

Conclusione del percorso

All'esito del triennio, l'attività di ricerca è giunta a compimento con la redazione della tesi di dottorato dal titolo "Prevenzione e mitigazione dei data breach e degli incidenti di sicurezza informatica nelle imprese e nelle pubbliche amministrazioni" [indicare l'eventuale sottotitolo], composta da un'introduzione, quattro parti articolate in tredici capitoli e una bibliografia, per complessive 520 pagine circa. La ricerca si è pertanto conclusa nei tempi previsti dal progetto, e i risultati conseguiti costituiscono la base del programma di ricerca post-dottorale delineato nelle conclusioni della tesi.

Partecipazione ad attività formative

Il sottoscritto ha partecipato alle sottoelencate attività formative:

- 22 luglio 2026 – Camera dei deputati, XIV Commissione (Politiche dell'Unione europea). Audizione informale, in videoconferenza, nell'ambito dell'esame dello schema di decreto legislativo recante adeguamento della normativa nazionale alle disposizioni del regolamento (UE) 2024/1689 del Parlamento europeo e del Consiglio, del 13 giugno 2024, che stabilisce regole armonizzate sull'intelligenza artificiale, in materia di utilizzo dei sistemi di intelligenza artificiale per l'attività di polizia e di responsabilità penale e civile (atto n. 418), con deposito di una relazione scritta;
- [completare con seminari, discussioni dottorali, Settimana dottorale 2026, convegni e relazioni del periodo 1° novembre 2025 – 31 ottobre 2026, indicando i CFU ove previsti].

Pubblicazioni prodotte nel periodo di riferimento

- F.P. Micozzi, "Sfide e opportunità nel recepimento della direttiva dell'UE sulle misure per un livello comune elevato di cibersicurezza (NIS2)", in A. Gattini (a cura di), *La tecno-sovranità nella prospettiva del diritto internazionale*, Giappichelli, Torino, 2026;
- F.P. Micozzi, *Relazione per l'audizione. Schema di decreto legislativo A.G. n. 418, impiego dell'intelligenza artificiale nelle attività di polizia*, Camera dei deputati, XIV Commissione (Politiche dell'Unione europea), 22 luglio 2026;
- [verificare se pubblicato] F.P. Micozzi, "Propostas regulatórias para Inteligência Artificial. Regulação europeia (AI Act)", in C. Carvajal, H. Marcello dos Reis, R. Limongi (org.), *Direito, gestão e Inteligência Artificial na era dos dados*, Quartier Latin, Brasile;
- [verificare se pubblicato] contributo su AI e sicurezza informatica negli atti del congresso giuridico forense del Lazio "Il futuro della Giustizia ed il ruolo dell'Avvocatura", a cura dell'Unione degli Ordini Forensi del Lazio.

Cagliari-Perugia, 30 ottobre 2026 Francesco Paolo Micozzi

Parere del tutor in merito alla relazione

Il sottoscritto, Professor Andrea Sassi, in qualità di supervisore del dottorando Francesco Paolo Micozzi, comunica che lo stesso ha svolto con costante interesse e lodevole impegno l'attività di ricerca, presso la sede di servizio del Dipartimento di Giurisprudenza.

Perugia, 31 ottobre 2026 Prof. Andrea Sassi